

ACME Waters

Plan Integral de Ciberseguridad

Resumen Ejecutivo

Documento de alta dirección basado en los anexos técnicos finales

Tipo de documento	Resumen ejecutivo
Alcance	Estrategia, organización, análisis de riesgos, arquitectura y respuesta
Fecha	Julio de 2026

Índice

Sección	Pág.
Introducción / preámbulo	2
FASE 1. Estrategia de ciberseguridad	4
FASE 2. Organización del área de ciberseguridad	7
FASE 3. Plan de acción	10
FASE 3.1. Análisis de riesgos	10
FASE 3.2. Gestión de la ciberseguridad y arquitectura tecnológica	13
FASE 3.3. Respuesta a ciberataques	17
Cierre	20

Introducción / preámbulo

Este documento presenta, en lenguaje de alta dirección, el Plan Integral de Ciberseguridad de ACME Waters. Su finalidad es consolidar en una única lectura ejecutiva las decisiones esenciales de estrategia, organización, análisis de riesgos, arquitectura tecnológica y respuesta a ciberataques, manteniendo el detalle completo en el documento de anexos técnicos. El resumen no sustituye a los anexos: los utiliza como respaldo para que cada decisión pueda rastrearse hasta una evidencia, una tabla, una figura o un procedimiento documentado.

ACME Waters presta servicios vinculados al ciclo integral del agua, atiende a una base amplia de abonados y opera con dependencias tecnológicas que afectan a clientes, sedes, proveedores, aplicaciones corporativas, servicios cloud, teletrabajo, CPD y relaciones con entornos operacionales. Por ello, la ciberseguridad no puede tratarse como una cuestión exclusivamente informática. El criterio rector del plan es proteger la continuidad del servicio esencial, la confianza pública, la seguridad de la información, la privacidad y la capacidad de recuperación de la organización.

El alcance del presente documento cubre cinco bloques: una estrategia de ciberseguridad alineada con ENS, NIST CSF 2.0, protección de datos y continuidad; un modelo organizativo que separa gobierno y operación; un análisis de riesgos que prioriza escenarios de impacto real; una arquitectura de seguridad con proyectos y presupuesto a tres años; y un modelo de respuesta a ciberataques con severidad, evidencias, runbooks y recuperación coordinada. El plan queda además situado en una visión macro a cinco años, de forma que el despliegue trienal no se entienda como un cierre, sino como la primera etapa de madurez verificable.

La lectura debe hacerse con dos ideas en mente. La primera es que el plan no pretende comprar herramientas por acumulación, sino crear una capacidad corporativa medible: responsables, procesos, controles, evidencias, métricas y mejora continua. La segunda es que la automatización y la tecnología se subordinan a criterios de negocio, continuidad, legalidad, protección de datos y operación segura. En particular, cualquier interacción con entornos OT o procesos industriales debe tratarse con prudencia: disponibilidad, safety, calidad del agua, medioambiente y continuidad operacional prevalecen sobre acciones técnicas invasivas.

El documento de anexos técnicos contiene el detalle completo. Este resumen remite de forma expresa a las figuras y tablas más relevantes: los pilares estratégicos se desarrollan en el Anexo I, Figuras 1 y 2; el modelo organizativo en el Anexo II, Figura 3 y Tabla 1; el análisis de riesgos, arquitectura lógica y BIA en el Anexo III, especialmente Tablas 2 a 12 y Figuras 5 a 9; la cartera P1-P12, roadmap, arquitectura objetivo y presupuesto en el Anexo IV, Tablas 13 a 16 y Figuras 10 y 11; y la respuesta a ciberataques en el Anexo V, Tablas 17 a 156.

Bloque en el resumen ejecutivo	Referencia principal en anexos	Uso
Estrategia	Anexo I, Figuras 1-2	Define visión, principios, pilares, horizonte a cinco años y métricas de dirección.
Organización	Anexo II, Figura 3 y Tabla 1	Explica el modelo DC/DIS, gobierno, comités, RACI y servicios gestionados.
Riesgos y BIA	Anexo III, Tablas 2-12 y Figuras 5-9	Prioriza amenazas, activos, continuidad, teletrabajo, arquitectura lógica y BIA preliminar.
Arquitectura y roadmap	Anexo IV, Tablas 13-16 y Figuras 10-11	Ordena proyectos P1-P12, capacidades, presupuesto y secuencia de tres años.
Respuesta a ciberataques	Anexo V, Tablas 17-156	Establece severidad, evidencias, SOAR, runbooks, recuperación y plantillas de cierre.

Tabla 1. Mapa de referencias a los anexos técnicos.

El criterio de redacción de este resumen es deliberadamente ejecutivo. Elementos tales como reglas técnicas, consultas SIEM, configuraciones, playbooks invasivos y procedimientos operativos extensos se desarrollan en los Anexos Técnicos que acompañan al presente documento.

FASE 1. Estrategia de ciberseguridad

La estrategia de ciberseguridad de ACME Waters establece el marco que da coherencia al resto del plan. Su objetivo es pasar de un enfoque reactivo, centrado en resolver problemas aislados, a un modelo gobernado por riesgo, cumplimiento, continuidad y resiliencia. Esta transformación exige que la ciberseguridad forme parte de la agenda directiva, con responsabilidades claras, objetivos medibles y decisiones vinculadas al impacto sobre los servicios esenciales.

El punto de partida es favorable: la organización reconoce la necesidad de reforzar la seguridad, dispone de capacidad presupuestaria y cuenta con servicios críticos que justifican un modelo de madurez alto. Al mismo tiempo, la dependencia de aplicaciones como MAIN, CRM, ERP, Oficina Virtual, Tienda Online y AQUAPP; el uso de cloud y teletrabajo; la relación con proveedores; y la existencia de conexiones o dependencias con entornos operacionales hacen necesario un enfoque integral. El CPD es un núcleo crítico, pero no una isla: su exposición depende de identidades, usuarios, sedes, proveedores, comunicaciones, aplicaciones y procesos de negocio.

El marco rector combina cumplimiento nacional e internacional. El Esquema Nacional de Seguridad proporciona una referencia exigente para evidencias, responsables, medidas, auditoría y mejora continua. NIST CSF 2.0 aporta un lenguaje corporativo de madurez basado en gobernar, identificar, proteger, detectar, responder y recuperar. Junto a ellos, ISO/IEC 27001, ISO/IEC 27005, NIST SP 800-61, NIST SP 800-82, NIST SP 800-207, ISA/IEC 62443, ENISA, CCN-CERT e INCIBE permiten sostener decisiones sin convertir el plan en una acumulación de marcos.

La visión propuesta es que ACME se convierta en una organización resiliente, confiable y verificable. Resiliente, porque debe poder mantener o recuperar servicios críticos ante ataques, fallos o degradaciones. Confiable, porque gestiona datos personales, relaciones contractuales, servicios públicos y expectativas de usuarios. Verificable, porque cada control relevante debe poder demostrarse mediante evidencias: políticas, registros, pruebas, métricas, auditorías y decisiones documentadas.

La estrategia se ordena en siete pilares. Primero, gobierno y cumplimiento, para que las decisiones de seguridad tengan autoridad y seguimiento. Segundo, conocimiento de activos y riesgos, porque no se puede proteger lo que no está inventariado o no se entiende. Tercero, arquitectura segura, basada en defensa en profundidad, identidad, segmentación, cifrado, hardening y control de exposición. Cuarto, protección de datos y confianza digital, especialmente en aplicaciones de cliente. Quinto, detección y respuesta, con capacidad real de identificar, escalar y actuar. Sexto, continuidad y recuperación, centrada en restauración probada y servicio esencial. Séptimo, cultura y cambio organizativo, porque la seguridad depende también de hábitos, formación y responsabilidad compartida.



Figura 1. Pilares de la estrategia de ciberseguridad de ACME Waters.

La estrategia fija además un horizonte temporal equilibrado. El primer año se centra en construir las bases: gobierno, inventario, mapa normativo, análisis de riesgos, políticas, controles urgentes, protección del CPD crítico y capacidad mínima de detección y respuesta. El segundo año consolida arquitectura, servicios gestionados, seguridad cloud, vulnerabilidades, continuidad, pruebas y métricas. El tercer año eleva madurez mediante automatización controlada, integración de capacidades, ejercicios avanzados, proveedores y mejora continua. Los años cuarto y quinto permiten optimizar, auditar, homogeneizar internacionalmente y reforzar la resiliencia corporativa.

Para que el plan sea gobernable, la medición debe diferenciar actividad y eficacia. No basta con contabilizar usuarios formados, alertas recibidas o herramientas desplegadas. El comité debe recibir indicadores que expliquen reducción de exposición, riesgos tratados, activos críticos inventariados, cobertura de MFA/PAM, vulnerabilidades críticas corregidas en plazo, restauraciones probadas, calidad de logs, participación de proveedores y ejercicios de crisis realizados. Esta lectura evita una falsa sensación de avance basada solo en volumen de tareas.

El plan macro a cinco años cumple una función de control. Los tres primeros años construyen la base financiable y ejecutable; los dos siguientes permiten revisar madurez, consolidar certificaciones o auditorías avanzadas, mejorar resiliencia internacional y adaptar el modelo a nuevas obligaciones. Esta distinción es importante: el roadmap trienal es un programa de implantación; el horizonte quinquenal es el mecanismo para mantener la ciberseguridad como capacidad permanente de gobierno.

Este horizonte no debe confundirse con una promesa de despliegue cerrado. El roadmap a tres años ordena prioridades y presupuestos; el plan macro a cinco años sitúa la evolución de madurez. La diferencia es relevante para dirección: el trienio permite financiar, ejecutar y medir

proyectos concretos; el quinquenio evita que la ciberseguridad quede congelada una vez implantadas las capacidades iniciales. La amenaza, la regulación, el negocio y la tecnología evolucionan, por lo que el plan debe revisarse al menos anualmente y siempre tras incidentes graves, cambios regulatorios o modificaciones sustanciales del entorno tecnológico.

La dimensión legal se integra desde el inicio. ACME debe atender ENS, RGPD, LOPDGDD, normativa NIS/NIS2, régimen de infraestructuras críticas cuando aplique, obligaciones de servicios digitales, contratación, continuidad, proveedores y derechos digitales. El enfoque recomendado no es de cumplimiento mínimo, sino de cumplimiento reforzado: identificar obligaciones, asignar responsables, desplegar controles, producir evidencias, auditar y corregir. Esta lógica evita que el cumplimiento sea una capa documental separada de la operación.

En términos de decisión, la FASE 1 aporta el marco de gobierno que justifica el resto del plan. Las inversiones, la organización, el análisis de riesgos, la arquitectura y la respuesta a incidentes no son piezas sueltas: derivan de una misma estrategia. Las referencias detalladas se encuentran en el Anexo I, especialmente en las Figuras 1 y 2 y en los apartados de visión, pilares, marco regulatorio, horizonte y medición.

FASE 2. Organización del área de ciberseguridad

La organización propuesta traduce la estrategia en un modelo de gestión. ACME necesita separar con claridad el gobierno de la ciberseguridad y su operación técnica. Esta separación no es burocrática: permite que quien define políticas, riesgos, controles, evidencias y reporting no sea el único que opera las herramientas o evalúa su propio cumplimiento. El modelo se articula mediante un Departamento de Ciberseguridad, orientado a gobierno y riesgo, y un Departamento de Infraestructura de Seguridad, orientado a operación técnica y servicios.

El CISO/RSI actúa como responsable de gobierno, estrategia, reporting y coordinación con dirección. El CIO mantiene la responsabilidad sobre operación tecnológica, infraestructura y ejecución técnica. La relación entre ambos debe ser cooperativa, pero con funciones diferenciadas: el CISO establece criterios, supervisa riesgos y exige evidencias; el CIO asegura la implantación, disponibilidad y calidad operativa de las plataformas. Este modelo permite integrar la ciberseguridad en la gestión corporativa sin diluirla dentro de TI.

La organización no se limita a la sede central. La Sede Central de Ceuta opera como nodo de gobierno y decisión, pero el modelo debe extenderse a sedes, servicios, proveedores y relaciones internacionales. En empresas del ciclo del agua, la coordinación con Operaciones es especialmente importante: los criterios de seguridad deben convivir con disponibilidad, seguridad operacional, calidad del agua, medioambiente, mantenimiento y continuidad. La organización debe permitir que las decisiones críticas de seguridad incorporen estas perspectivas antes de ejecutar cambios de impacto.

Organigrama funcional del modelo DC/DIS

Separación entre gobierno, operación técnica y coordinación corporativa

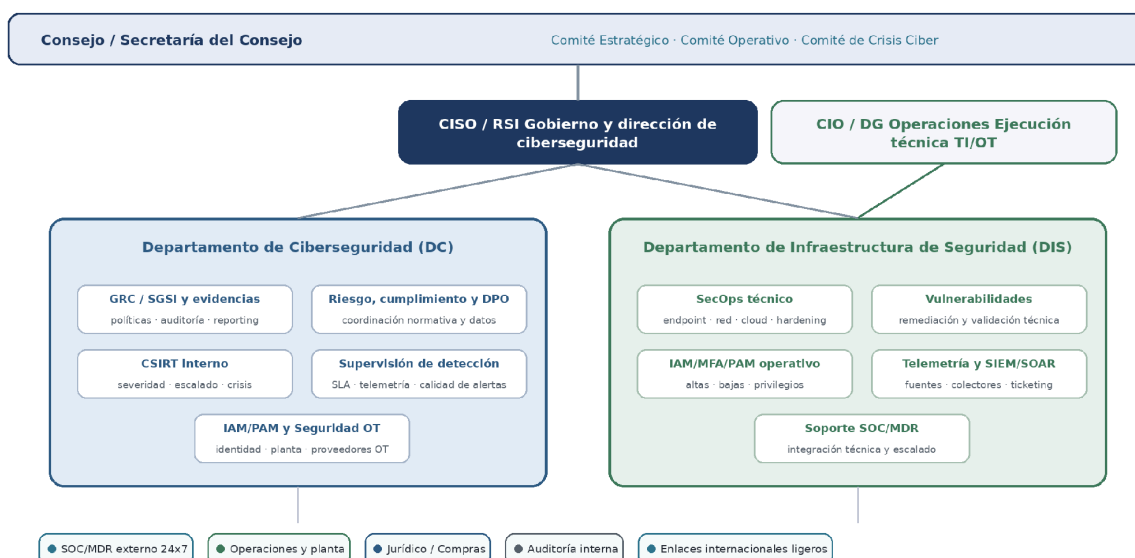


Figura 2. Modelo funcional DC/DIS y coordinación con dirección, TI, SOC/MDR y Operaciones.

El modelo de gobierno se apoya en comités. El Comité Estratégico fija apetito de riesgo, prioridades, presupuesto y reporting al Consejo. El Comité Operativo transforma esas prioridades

en proyectos, métricas, tratamiento de riesgos y seguimiento de controles. El Comité de Crisis se activa ante incidentes relevantes y reúne dirección, CISO, CIO, continuidad, comunicación, jurídico, protección de datos, responsables de negocio y Operaciones cuando exista impacto en servicio esencial o entornos industriales. Esta estructura evita improvisación y proporciona una ruta de escalado clara.

Las capacidades se priorizan por valor directivo, no por moda tecnológica. Primero debe existir gobierno: políticas, propietarios, decisiones y evidencias. Después, conocimiento: inventario, criticidad, dependencias y riesgos. Sobre esa base se despliegan identidad, acceso privilegiado, visibilidad, detección, protección de endpoint, gestión de vulnerabilidades, continuidad, proveedores, seguridad de aplicaciones y respuesta a incidentes. Esta secuencia reduce el riesgo de invertir en herramientas sin datos fiables, sin responsables o sin capacidad de explotación real.

Los servicios gestionados tienen un papel relevante porque ACME busca un nivel alto de cumplimiento y madurez. SOC/MDR, gestión de vulnerabilidades, apoyo DFIR, inteligencia de amenazas, auditoría, formación especializada y soporte en seguridad OT pueden aportar velocidad, experiencia y cobertura 24x7. Sin embargo, externalizar no equivale a delegar la responsabilidad. ACME conserva la decisión, la supervisión, la exigencia contractual, la priorización por riesgo y la aceptación de riesgos residuales.

El presupuesto organizativo a tres años debe leerse como una previsión orientativa, no como una cifra cerrada independiente del inventario. Los anexos proponen rangos que permiten planificar contratación, servicios gestionados, auditoría, formación y contingencia. La recomendación ejecutiva es financiar primero las capacidades que habilitan el resto: gobierno, inventario, identidad, SOC/MDR, vulnerabilidades, PAM, continuidad y seguridad OT prudente. La mejora de madurez no depende de una única contratación, sino de combinar estructura interna, proveedores adecuados y métricas de eficacia.

La participación del CISO en comités de negocio es imprescindible. Ciberseguridad debe intervenir en decisiones de continuidad, contratación, transformación digital, cloud, aplicaciones, proveedores, auditoría, protección de datos y crisis. En ACME, además, debe participar en foros donde se analicen dependencias con operación, atención a abonados, trámites online y proveedores críticos. Esta presencia evita que la seguridad llegue tarde, cuando el contrato está firmado, la aplicación desplegada o la dependencia operacional ya creada.

El RACI resumido del Anexo II debe utilizarse como herramienta de decisión. La alta dirección no necesita conocer cada tarea técnica, pero sí qué área responde, quién aprueba, quién consulta y quién debe ser informado en procesos como gestión de riesgos, incidentes, continuidad, proveedores, accesos privilegiados, protección de datos, auditoría y seguridad OT. Esta claridad reduce conflictos durante la operación ordinaria y, sobre todo, durante una crisis.

La organización también debe asegurar una transición ordenada. En el primer año conviene priorizar funciones críticas y servicios gestionados que aceleren la madurez sin crear dependencia ciega. En el segundo y tercer año, el conocimiento debe transferirse progresivamente a equipos internos, manteniendo proveedores donde aporten cobertura, especialización o eficiencia. El objetivo no es externalizar la ciberseguridad, sino construir una organización capaz de gobernarla.

En síntesis, la FASE 2 convierte la estrategia en una estructura de gobierno aplicable. Define quién decide, quién opera, quién valida, quién informa y quién responde. El detalle de organigrama, RACI, servicios gestionados, comités, indicadores y presupuesto se recoge en el Anexo II, con especial referencia a la Figura 3 y la Tabla 1.

FASE 3. Plan de acción

La FASE 3 convierte estrategia y organización en acción. Se estructura en tres subfases complementarias: análisis de riesgos, gestión de la ciberseguridad y arquitectura tecnológica, y respuesta a ciberataques. El objetivo común es que ACME no solo declare una ambición de madurez, sino que disponga de prioridades, proyectos, servicios, evidencias y procedimientos para reducir riesgo real.

La lógica del plan es progresiva. Primero se entiende el riesgo: activos, amenazas, vulnerabilidades, impacto, continuidad y dependencias. Después se diseña la arquitectura de capacidades: proyectos, servicios, herramientas, presupuesto, roadmap y métricas. Finalmente se define cómo responder cuando el riesgo se materializa: severidad, roles, evidencias, runbooks, recuperación y mejora. Esta secuencia es procedimentalmente correcta porque evita diseñar una respuesta desconectada del riesgo o comprar tecnología sin un criterio de priorización.

El plan a tres años debe ejecutarse con disciplina de gobierno. Cada proyecto debe tener propietario, objetivo, alcance, dependencia, evidencia esperada, presupuesto y criterio de éxito. Las decisiones críticas (como por ejemplo contención de sistemas, recuperación, reactivación de accesos, activación de continuidad o comunicación externa) deben quedar documentadas. El plan macro a cinco años permite revisar madurez, extender controles, consolidar métricas y adaptar la estrategia a cambios regulatorios, tecnológicos o de amenaza.

El enfoque recomendado no promete seguridad absoluta. Los controles reducen probabilidad e impacto, pero no eliminan el riesgo. Por eso el plan combina prevención, detección, respuesta y recuperación. ACME debe asumir que algunos incidentes ocurrirán y que la diferencia entre una crisis controlada y una crisis desordenada estará en la preparación, la trazabilidad, la calidad de evidencias, la coordinación y la validación de negocio.

FASE 3.1. Análisis de riesgos

El análisis de riesgos parte de una necesidad directiva: saber qué proteger primero y por qué. ACME dispone de aplicaciones y servicios de alta criticidad, exposición a Internet, identidades privilegiadas, proveedores, teletrabajo, cloud y posibles dependencias con entornos OT. La priorización no puede hacerse únicamente por severidad técnica; debe considerar impacto sobre abonados, continuidad del agua, datos personales, operación, reputación, cumplimiento y capacidad de recuperación.

El plan de auditoría se centra en servicios críticos. Define ámbito, equipo, dedicación, metodología, evidencias y criterios de cierre. A nivel ejecutivo, lo importante es que la auditoría no se limita a buscar vulnerabilidades: debe producir una visión accionable de riesgos, exposición, controles existentes, brechas, dependencias y decisiones necesarias. El detalle del ámbito y equipo está recogido en el Anexo III, Tablas 2 y 3, y el plan de auditoría en la Tabla 4.

La metodología seleccionada combina criterios de impacto, probabilidad, criticidad de activos, exposición y eficacia de salvaguardas. Esto permite comparar riesgos de naturaleza distinta: ransomware, compromiso de identidad, explotación web/API, cloud/correo, proveedor, teletrabajo, DDoS, phishing, vulnerabilidades críticas e interconexiones IT/OT. El resultado son riesgos R1-R11 y vulnerabilidades V1-V12, tratados como base para el Plan Director y los runbooks de respuesta.

Un elemento relevante del análisis es la evaluación de riesgo residual con salvaguardas de eficacia L5. Este ejercicio no pretende demostrar que el riesgo desaparece, sino ilustrar cómo controles robustos pueden reducir probabilidad o impacto si están correctamente implantados, monitorizados y probados. La reducción de riesgo debe entenderse siempre como estimación: depende de inventario, configuración, cobertura, operación, evidencias y comportamiento de usuarios y proveedores. El detalle se recoge en el Anexo III, Tabla 7 y Figura 5.

La arquitectura lógica de red, el plan de nomenclatura de activos, las redes necesarias y los puertos estándar permiten construir una base de gobierno. Su valor está en ordenar la conversación: qué activos existen, dónde están, qué servicios soportan, qué flujos son necesarios, qué exposición se acepta y qué controles deben protegerlos. No se trata de fijar reglas técnicas definitivas en este resumen, sino de asegurar que el Plan Director no parte de supuestos débiles. Las referencias principales son el Anexo III, Tablas 6, 8 y 9, y Figuras 6 y 7.

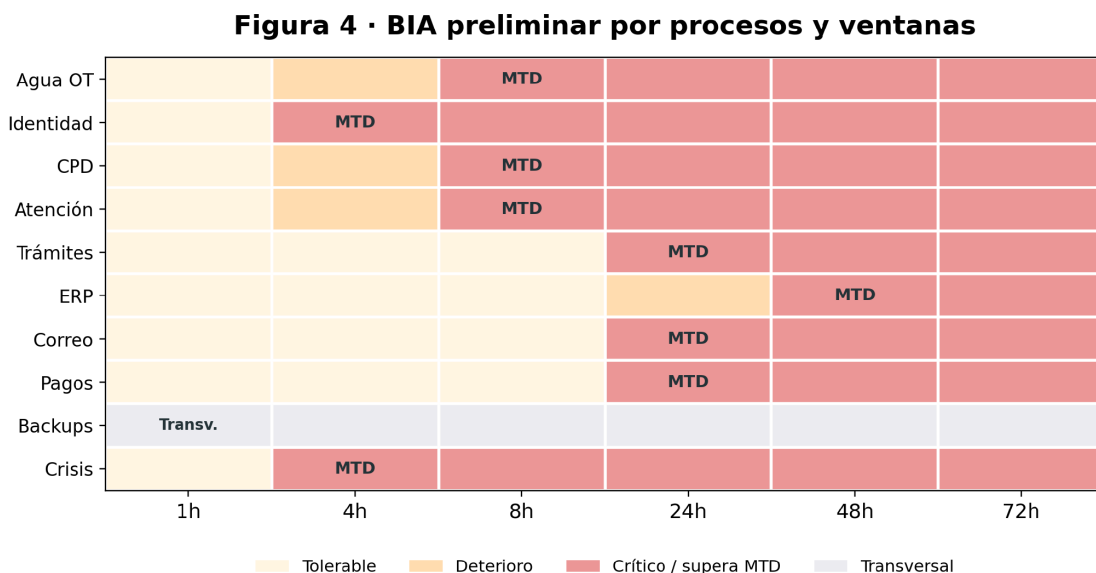
El teletrabajo se trata como una fuente de riesgo y como una necesidad operativa. La propuesta evita el acceso plano a la red interna y diferencia perfiles: administración TI, usuarios corporativos, dirección, atención, personal de campo y proveedores. La disponibilidad ampliada de TI se mantiene bajo guardia autorizada, MFA, PAM, bastión, registro y aprobación. Para el resto de perfiles, el acceso debe respetar rol, dispositivo, jornada, desconexión digital, bajas y condiciones de seguridad. El detalle se resume en el Anexo III, Tabla 10 y Figura 8.

El BIA preliminar es una de las piezas más importantes para dirección. Permite relacionar procesos críticos con aplicaciones, impacto, MTD, RTO, RPO y soluciones de recuperación. Debe leerse como hipótesis de priorización, no como compromiso aprobado. MTD indica cuánto puede tolerar el negocio una interrupción; RTO orienta el objetivo de recuperación; RPO orienta la pérdida máxima de datos aceptable. Estos valores requieren validación posterior con propietarios de proceso, TI, Operaciones, continuidad, proveedores y evidencias de prueba.

Proceso crítico	Lectura ejecutiva	Hipótesis orientativa
Continuidad operacional del agua	Máxima prioridad si afecta continuidad, calidad del agua, safety o medioambiente.	MTD 2-8 h según instalación; RTO 1-4 h para supervisión central; RPO 15-60 min para datos críticos.
Identidad corporativa	Habilita administración, teletrabajo, aplicaciones y recuperación.	MTD 4 h; RTO 1-2 h para servicios mínimos; RPO ≤1 h en cambios críticos.
CPD y virtualización	Afecta múltiples aplicaciones y puede bloquear la recuperación ordenada.	MTD 4-8 h; RTO 2-4 h en servicios base; RPO ≤1 h en servicios críticos.

Atención a abonados	Impacto reputacional y saturación de canales alternativos.	MTD 8 h; RTO 4 h para atención mínima; RPO 1 h con conciliación si procede.
Trámites online	Afecta pagos, gestiones, comunicación con abonados y presión sobre atención.	MTD 24 h; RTO 8 h para servicio mínimo; RPO 2-4 h según trámite.
Correo y colaboración	Clave para coordinación ordinaria y crisis.	MTD 24 h; canal de crisis 2-4 h; RTO 1 h para comunicación alternativa.

Tabla 2. Síntesis ejecutiva del BIA preliminar. Detalle completo en Anexo III, Tabla 11.



Valores orientativos; pendientes de validación de negocio, TI, Operaciones, DPD y proveedores. No son RTO/RPO aprobados.

Figura 3. Vista ejecutiva del BIA preliminar por procesos y ventanas temporales.

El uso correcto del BIA es condicionar prioridades sin crear falsas garantías. Si un incidente afecta identidad, CPD, backups o continuidad operacional, la recuperación debe priorizarse por dependencia y servicio esencial, no solo por orden de llegada. Del mismo modo, no se debe prometer recuperación sin pruebas, evidencias, responsables, origen de restauración confiable y validación funcional de negocio u Operaciones. Esta cautela se mantiene también en la respuesta a incidentes, donde el Anexo V relaciona recuperación, BIA, PCN, PCTIC y PRD.

El análisis de riesgos concluye que las amenazas prioritarias deben tratarse como escenarios conectados. Un phishing puede derivar en compromiso de identidad; una identidad comprometida puede afectar cloud, correo o administración; una vulnerabilidad crítica puede facilitar ransomware; un proveedor puede convertirse en vector de propagación; y una degradación TI puede impactar procesos operacionales. Por eso, el plan vincula riesgos, controles, arquitectura, detección, runbooks y recuperación.

FASE 3.2. Gestión de la ciberseguridad y arquitectura tecnológica

La arquitectura tecnológica convierte el análisis de riesgos en una cartera de capacidades. El Plan Director se estructura en proyectos P1-P12, diseñados para cubrir gobierno, inventario, identidad, endpoint, SOC/MDR, SIEM, SOAR, segmentación, aplicaciones públicas, vulnerabilidades, cifrado, backups, proveedores y mejora continua. La cartera completa se recoge en el Anexo IV, Tabla 13.

La decisión ejecutiva más importante es que la arquitectura no se plantea como catálogo de productos. Las herramientas son medios para lograr visibilidad, control, detección, respuesta y recuperación. Un SIEM sin logs fiables no aporta valor suficiente; un PAM sin revisión de cuentas privilegiadas y de servicio no reduce todo el riesgo; un backup sin restauración probada no garantiza continuidad; y una automatización sin aprobación humana puede aumentar el impacto si actúa sobre sistemas críticos.

El modelo global de servicios combina capacidades internas y gestionadas. SOC/MDR proporciona cobertura y experiencia; SIEM centraliza visibilidad; SOAR ayuda a enriquecer, notificar y orquestar tareas con límites; EDR/XDR protege endpoints y servidores; WAF/API reduce exposición de aplicaciones públicas; IAM/MFA/PAM gobierna identidad y privilegios; MDM protege movilidad; y backups/recuperación sostienen resiliencia ante ransomware, fallo grave o corrupción. Cada servicio debe tener propietario, alcance, métrica, evidencias y dependencia presupuestaria.

La selección de Microsoft Sentinel como SIEM principal y Sentinel Automation/Logic Apps como base SOAR inicial se justifica por integración, escalabilidad y encaje con identidad, cloud, correo y automatización. Esta decisión no debe leerse como dependencia acrítica de una marca, sino como elección de plataforma para articular visibilidad, investigación, ticketing, evidencias y reporting. Los costes deben gobernarse mediante control de ingesta, retención, normalización y priorización de fuentes críticas. El análisis comparativo se recoge en el Anexo IV, Tablas 14 y 15.

La estrategia de cifrado se orienta a cumplir regulación y proteger datos en reposo, tránsito, backups, dispositivos, secretos y claves. A nivel directivo, la decisión es tratar el cifrado como parte de un gobierno de datos: clasificación, acceso mínimo, gestión de claves, rotación, separación de funciones, registro y revisión. Esto evita que el cifrado sea un control aislado sin trazabilidad o sin relación con procesos de negocio.

La gestión de vulnerabilidades debe ser continua y priorizada. No basta con listar CVE o aplicar parches en orden técnico. La priorización debe considerar exposición, explotación conocida, criticidad del activo, dependencia con servicio esencial, disponibilidad de workaround, ventana de mantenimiento, impacto en OT y riesgo residual aceptado. El plan evita pruebas agresivas sobre producción y exige especial prudencia en entornos industriales, donde escaneos activos, reinicios o cambios no autorizados pueden afectar disponibilidad o safety.

El roadmap a tres años ordena la implantación. En el Año 1 se construyen bases gobernables: inventario crítico, ENS/SGSI, IAM/MFA/PAM inicial, SIEM productivo inicial, MDR/SOC, EDR/XDR prioritario, backups segregados, vulnerabilidades, cifrado base, proveedores críticos y frontera IT/OT. En el Año 2 se amplía cobertura: normalización de logs, SOAR inicial, WAF/API, MDM/DLP, NDR crítico, segmentación y restauraciones de aplicaciones críticas. En el Año 3 se optimiza: costes, automatización con aprobación humana, reporting maduro, PAM extendido, cuentas de servicio, pruebas integradas y madurez IT/OT.

Roadmap tecnológico a 3 años

Secuencia priorizada para implantar capacidades, consolidarlas y optimizarlas sin duplicar el plan global a cinco años.



Figura 4. Roadmap de implantación tecnológica a tres años.

Horizonte	Prioridad directiva	Resultado esperado
Año 1	Base gobernable: gobierno, inventario, identidad, SOC/MDR, SIEM inicial, EDR, backups, vulnerabilidades y proveedores críticos.	Capacidad mínima de control, visibilidad y recuperación sobre activos prioritarios.
Año 2	Cobertura y consolidación: SOAR inicial, WAF/API, MDM/DLP, segmentación, NDR, cloud/correo, restauraciones y seguridad OT prudente.	Mayor cobertura de servicios críticos y reducción de exposición material.
Año 3	Madurez y optimización: automatización controlada, reporting, PAM extendido, cuentas de servicio, ejercicios integrados y mejora continua.	Modelo medible, auditable y preparado para expansión/optimización a cinco años.
Macro 5 años	Auditoría avanzada, mejora internacional, resiliencia corporativa y actualización frente a cambios regulatorios y amenazas.	Ciberseguridad integrada en gobierno corporativo, continuidad y ciclo de inversión.

Tabla 3. Lectura ejecutiva del roadmap de implantación. Detalle completo en Anexo IV, Tabla 15 y Figura 11.

El presupuesto tecnológico trienal es orientativo y debe validarse con inventario real, licenciamiento, volumen de logs, número de usuarios, retención, criticidad, contratos y alcance internacional. El Anexo IV, Tabla 16, estima líneas de inversión como gobierno/ENS/SGSI, IAM/MFA/PAM, SIEM/MDR/SOC, SOAR, EDR/XDR/MDM, vulnerabilidades/WAF/cloud/correo, cifrado, backups/recuperación, frontera IT/OT y gestión de terceros. La lectura ejecutiva es que el mayor peso presupuestario se concentra donde hay mayor reducción de riesgo: identidad, visibilidad, respuesta, vulnerabilidades, recuperación y protección de servicios expuestos.

Línea de inversión	Rango trienal estimado	Justificación ejecutiva
SIEM, SOC/MDR y retención	810-1.270 k€	Visibilidad, detección, investigación y reporting sobre servicios críticos.
Vulnerabilidades, WAF/API y cloud/correo	590-910 k€	Reducción de exposición en aplicaciones públicas, servicios cloud y superficies explotables.
EDR/XDR, MDM y código malicioso	520-790 k€	Protección de servidores, portátiles, movilidad y teletrabajo.
Backups, recuperación y pruebas	480-760 k€	Resiliencia frente a ransomware, fallo grave y corrupción de datos.
Frontera IT/OT y acceso remoto industrial	410-680 k€	Control prudente de dependencias con operación y proveedores industriales.
IAM/MFA/PAM	390-610 k€	Reducción del riesgo de credenciales, privilegios y administración no trazable.
Gobierno, ENS, SGSI y auditoría	220-340 k€	Evidencias, cumplimiento, políticas, auditoría y seguimiento directivo.

Tabla 4. Síntesis presupuestaria ejecutiva a tres años. Detalle completo en Anexo IV, Tabla 16.

La arquitectura objetivo también define límites de automatización. La automatización debe empezar por tareas de bajo riesgo: enriquecimiento, creación de ticket, notificación, recopilación de evidencias, correlación y solicitud de aprobación. Las acciones críticas (bloqueo amplio, cambios de firewall, revocación masiva, restauración, reinicio de servicios o cualquier acción sobre OT) requieren aprobación humana, criterio de reversibilidad y validación del responsable correspondiente. Esta regla conecta directamente con la FASE 3.3.

La arquitectura tecnológica se complementa con un principio de recuperación limpia. La organización debe asumir que, en un incidente grave, recuperar rápido no es suficiente: hay que recuperar desde origen confiable, sin reintroducir persistencia, credenciales comprometidas, datos corruptos o configuraciones inseguras. Por eso el roadmap incluye backups segregados, pruebas de restauración, validación funcional, evidencias y coordinación con continuidad. La capacidad de recuperación no se declara: se demuestra.

En síntesis, la FASE 3.2 proporciona una hoja de ruta financiable y verificable. Su valor no está en la enumeración de productos, sino en la conexión entre riesgos, proyectos, servicios, presupuesto, métricas y secuencia temporal. El Anexo IV contiene el detalle de cartera, comparativas,

arquitectura, roadmap y presupuesto; este resumen retiene la lectura directiva necesaria para aprobar prioridades y controlar ejecución.

FASE 3.3. Respuesta a ciberataques

La respuesta a ciberataques define cómo decide y actúa ACME cuando se materializa un incidente. Su objetivo no es improvisar durante la crisis, sino disponer de un proceso conocido, roles definidos, severidades claras, evidencias mínimas, límites de automatización, runbooks y criterios de recuperación. El modelo se alinea con NIST SP 800-61 y con la trazabilidad del SGSI: riesgo, control, evidencia, decisión y mejora.

La severidad S0-S4 permite pasar de eventos informativos a crisis corporativa. La clasificación no depende solo del número de sistemas afectados; considera servicio esencial, datos personales, credenciales privilegiadas, proveedor crítico, continuidad, OT, reputación y obligaciones de comunicación. Un incidente puede escalar si aparecen nuevas evidencias, propagación, impacto en abonados o afectación a continuidad. También puede desescalar cuando se confirma que el impacto es limitado y existe control documentado.

El proceso común cubre detección, triaje, declaración, clasificación, investigación, contención, erradicación, recuperación, comunicación, cierre y lecciones aprendidas. Resulta relevante que cada decisión crítica tenga responsable y evidencia: quién aprueba, qué se sabe, qué alternativas se han valorado, qué impacto se espera, qué riesgo residual se acepta y cómo se revierte si algo falla. Este enfoque protege a la organización frente a respuestas precipitadas y frente a cierres sin aprendizaje.

Figura 2. Ciclo de vida de respuesta de ACME Waters

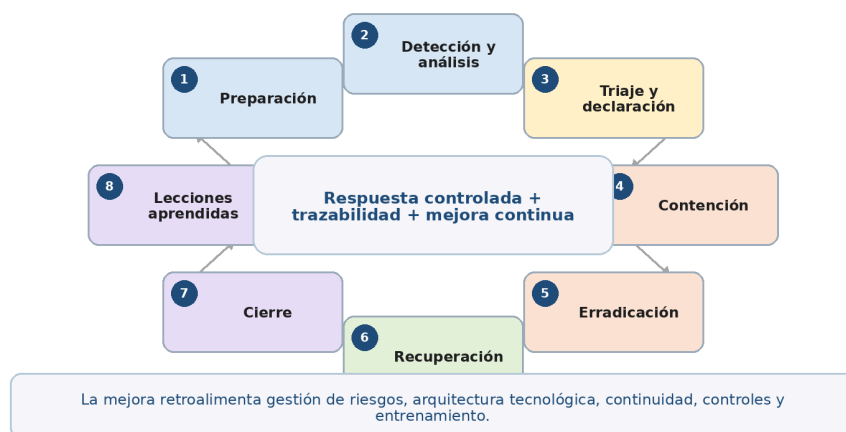


Figura 5. Ciclo de vida de respuesta de ACME Waters.

Los runbooks se mantienen en el anexo porque son autoexplicativos y operativos. En este resumen basta con señalar su cobertura: ransomware, identidad, web/API, cloud/correo, proveedor, IT/OT, CPD, vulnerabilidades críticas, teletrabajo, datos personales, DDoS y phishing. Cada runbook define disparadores, validación inicial, acciones, contención, recuperación, evidencias, comunicación, límites y cierre. La lista completa se encuentra en el Anexo V, Tablas 48 a 143.

Runbook	Escenario cubierto	Referencia en anexos
RB-01	Ransomware en CPD, servidores o backups	Anexo V, Tablas 48-55
RB-02	Compromiso de identidad, AD, VPN, MFA o PAM	Anexo V, Tablas 56-63
RB-03	Explotación web/API en Oficina Virtual, AQUAPP, CRM o APIs	Anexo V, Tablas 64-71
RB-04	Cloud/correo, BEC, OAuth o fuga SaaS	Anexo V, Tablas 72-79
RB-05	Proveedor crítico comprometido o caído	Anexo V, Tablas 80-87
RB-06	Alerta IT/OT o acceso remoto industrial sospechoso	Anexo V, Tablas 88-95
RB-07	Indisponibilidad del CPD o servicios base	Anexo V, Tablas 96-103
RB-08	Vulnerabilidad crítica o zero-day explorable	Anexo V, Tablas 104-111
RB-09	Endpoint/teletrabajo comprometido o dispositivo perdido	Anexo V, Tablas 112-119
RB-10	Brecha o exposición de datos personales	Anexo V, Tablas 120-127
RB-11	DDoS o indisponibilidad de servicios públicos	Anexo V, Tablas 128-135
RB-12	Campaña de phishing o robo de credenciales	Anexo V, Tablas 136-143

Tabla 5. Catálogo de runbooks de respuesta.

El uso de SOAR se formula con límites claros. La automatización inicial debe ayudar al SOC y al equipo de respuesta, no sustituir decisiones humanas críticas. Puede enriquecer alertas, crear tickets, recopilar evidencias, notificar, correlacionar y solicitar aprobaciones. No debe ejecutar contención automática en OT de producción, reinicios, escaneos activos, cambios de configuración o bloqueos masivos sin aprobación. Esta regla protege especialmente los entornos donde disponibilidad, safety, calidad del agua o continuidad operacional prevalecen sobre acciones técnicas rápidas.

La preservación de evidencias es una condición de calidad. Un incidente mal documentado puede resolverse técnicamente pero dejar a ACME sin trazabilidad, sin capacidad de aprendizaje y sin defensa ante obligaciones regulatorias, contractuales o de protección de datos. Por ello, la respuesta incluye fuentes de evidencia, cadena de custodia, separación entre hechos e hipótesis, registros de decisión, tickets maestros y plantillas de cierre. El detalle se desarrolla en el Anexo V, Tablas 34 a 38 y 150 a 156.

La recuperación se coordina con continuidad. La respuesta a incidentes no sustituye al PCN, PCTIC o PRD/DRP, pero los activa o alimenta cuando el impacto lo exige. La recuperación limpia requiere origen confiable, backup inmutable o aislado cuando aplique, restauración probada, validación técnica, prueba funcional, aprobación del dueño del servicio y monitorización reforzada.

Los RTO/RPO utilizados durante una crisis deben tratarse como hipótesis del BIA hasta que estén formalmente validados.

La preparación se completa con ejercicios. El comité debe exigir tabletop ejecutivo, simulacros técnicos, pruebas de restauración limpia, ejercicios con proveedores, pruebas de canales alternativos y escenarios IT/OT no intrusivos. Estos ejercicios no buscan dramatizar la amenaza, sino comprobar que las personas adecuadas toman decisiones con información suficiente, que existen canales fuera de banda, que la recuperación se valida y que las acciones de mejora tienen responsable y plazo.

Las métricas de respuesta deben medir capacidad real: tiempo de detección, tiempo de triaje, cobertura de evidencias, calidad de cierre, recalificación de severidad, tiempo de recuperación medido, éxito de restauración limpia, antigüedad de pruebas de backup y acciones correctivas vencidas. El valor para dirección está en detectar dónde falla el sistema: falta de logs, dependencia de proveedor, recuperación no probada, lentitud de aprobación o ausencia de dueño de servicio.

La comunicación de crisis debe ser precisa, sobria y aprobada. Dirección necesita información suficiente para decidir, pero no ruido operativo. Usuarios y clientes necesitan mensajes claros, no tecnicismos. Jurídico, DPD y Cumplimiento deben participar cuando hay datos personales, obligaciones de notificación, proveedores críticos o implicaciones regulatorias. Comunicación corporativa debe evitar tanto el silencio excesivo como afirmaciones no verificadas. La trazabilidad de decisiones protege a ACME durante y después del incidente.

En síntesis, la FASE 3.3 aporta la capacidad de actuar con orden. Un buen plan de respuesta no garantiza que no habrá incidentes, pero reduce el tiempo de decisión, evita improvisación, preserva evidencias, coordina recuperación y convierte cada crisis en mejora. El Anexo V contiene el detalle operativo; el comité debe retener la idea central: ante un ciberataque, ACME necesita autoridad, evidencias, límites, comunicación y retorno seguro, no solo herramientas.

Cierre

El Plan Integral de Ciberseguridad sitúa a ACME Waters en una senda madura y defendible. La propuesta cubre el enunciado completo: estrategia, organización, plan de acción, análisis de riesgos, gestión del entorno de ciberseguridad y gestión de ciberataques. También conecta gobierno, tecnología, continuidad, protección de datos, proveedores y operación, evitando que cada bloque funcione como una iniciativa aislada.

La principal decisión para la dirección es aprobar el plan como marco integrado. El valor no está en cada medida por separado, sino en la cadena completa: estrategia que fija principios, organización que asigna responsabilidades, análisis que prioriza riesgos, arquitectura que despliega capacidades, BIA que ordena recuperación, roadmap que financia la implantación, respuesta que gobierna incidentes y anexos que conservan el detalle técnico.

El roadmap de tres años proporciona una base procedimentalmente correcta para ejecutar: primero gobierno, inventario, identidad, visibilidad, recuperación y controles críticos; después ampliación y consolidación; finalmente madurez, automatización controlada y mejora continua. El plan macro a cinco años asegura que la ciberseguridad no se cierre como proyecto puntual, sino que evolucione con el negocio, la amenaza, la regulación y las dependencias tecnológicas.

El BIA preliminar debe mantenerse como herramienta de priorización y no como promesa cerrada. Sus hipótesis permiten decidir qué recuperar antes, qué dependencias proteger y cuándo activar continuidad, pero requieren validación con negocio, TI, Operaciones y proveedores. Esta cautela es especialmente importante en un operador del ciclo del agua, donde continuidad del servicio, calidad, safety y medioambiente pueden pesar más que la recuperación puramente informática.

La recomendación ejecutiva es avanzar con disciplina de gobierno: responsables claros, presupuesto trienal orientativo, métricas de eficacia, revisión anual, ejercicios de crisis y evidencia de recuperación. Las decisiones de inversión deben vincularse siempre a riesgos, controles y resultados verificables. Las capacidades técnicas deben implantarse con límites, aprobación humana y trazabilidad; especialmente en OT, proveedores, identidad y recuperación.

Con este enfoque, ACME Waters puede pasar de una ciberseguridad fragmentada a una capacidad corporativa de resiliencia: comprensible para dirección, exigible a equipos técnicos y proveedores, verificable mediante evidencias y alineada con la continuidad de un servicio esencial.